

Matriz de Evaluación PRAGMATIC de las métricas HyVAW

Escala por criterio: 1 (muy pobre) a 5 (excelente), siguiendo el enfoque PRAGMATIC Security Metrics.
[web:42][web:44][web:48]

1. Métricas de Cobertura (G1)

M1.1 - % de sistemas esenciales con análisis híbrido anual

Criterio	Puntuación	Justificación resumida
Predictivo (P)	4	Alta cobertura suele anticipar menor riesgo de vulnerabilidades desconocidas si la calidad del análisis es razonable.[web:3][web:16]
Relevante (R)	5	Directamente alineada con NIS2 y con la meta G1 de cobertura nacional.[web:18][web:23][web:36]
Accionable (A)	5	Valores bajos impulsan programas de extensión de HyVAW a más sistemas.
Genuino (G)	3	Depende de la honestidad en la definición de “análisis híbrido”; puede ser inflada.
Significativo (M)	4	Fácil de entender por dirección y reguladores: “qué parte del parque está cubierta”.
Preciso (A)	4	Requiere buen inventario; con éste, el cálculo es directo. [web:23][web:36]
Oportuno (T)	4	Puede actualizarse anualmente o incluso trimestralmente.
Independiente (I)	3	Normalmente autodeclarada por la organización; puede requerir auditoría.
Rentable (C)	5	Datos ya necesarios para NIS2; coste marginal bajo.[web:18][web:23]

Conclusión: Métrica muy fuerte, candidata central para panel nacional.

M1.2 – Índice de cobertura de activos críticos

Criterio	Puntuación	Justificación resumida
P	4	Una buena cobertura de activos críticos predice menor probabilidad de sorpresas desagradables.
R	5	Se alinea con la exigencia de NIS2 sobre gestión de activos y riesgos.[web:23][web:36]
A	4	Permite priorizar la expansión de HyVAW a activos no cubiertos.
G	3	Puede “maquillarse” si el inventario no es completo.
M	4	Significativo para CISO y regulador; algo técnico para niveles muy altos.
A	4	Cálculo relativamente sencillo con inventario estructurado.
T	3	Actualización suele ser anual; cambios más rápidos requieren disciplina.
I	3	Depende del inventario mantenido internamente.
C	4	Reutiliza información obligatoria para cumplimiento.

M1.3 – Distribución sectorial/tamaño de la cobertura

Criterio	Puntuación	Justificación resumida
P	3	Más útil como “fotografía comparativa” que como predictor directo.
R	4	Esencial para política pública y priorización de apoyo sectorial. [web:21][web:32]
A	4	Permite focalizar programas de ayuda, inspecciones o campañas.
G	4	Basada en agregados; menos susceptible a maquillaje individual.
M	4	Significativa para autoridades y foros sectoriales.
A	3	Requiere consolidación estadística; precisión media.
T	3	Ritmo razonable anual.
I	4	Mayor independencia al estar agregada y tratada por tercero (INCIBE/autoridad).
C	4	Coste moderado, aprovechando datos de encuesta y reportes.

2. Métricas de Calidad del Análisis (G2)

M2.1 – Tasa de falsos positivos críticos

Criterio	Puntuación	Justificación resumida
P	4	Alta tasa anticipa desgaste del equipo y menor eficacia; baja tasa predice procesos más eficientes.[web:8][web:19]
R	5	Directamente ligada a la eficacia del análisis híbrido.
A	5	Motiva revisión de herramientas, tuning y cambios de proceso.
G	3	Puede infraestimarse si no se validan sistemáticamente los hallazgos.
M	4	Muy significativa para equipos técnicos; requiere traducción para ejecutivos.
A	3	Precisión depende de la disciplina de clasificación TP/FP.
T	4	Puede medirse por ciclo de análisis o trimestralmente.
I	3	Tiende a ser interna; auditoría puede mejorar independencia.
C	3	Exige cierto esfuerzo de etiquetado; coste moderado. [web:48]

M2.2 – Proporción de vulnerabilidades críticas confirmadas dinámicamente

Criterio	Puntuación	Justificación resumida
P	4	Alta proporción indica mejor validación y menor ruido; predice mejor foco de remediación.[web:8][web:24]
R	5	Directamente alineada con el espíritu HyVAW.
A	4	Permite ajustar equilibrio entre análisis estático y dinámico.
G	4	Más difícil “maquillar” sin trabajo real de validación.
M	4	Clara para equipos técnicos; trasladable a ejecutivos como “verificación”.
A	3	Depende de registros de evidencias de pruebas.
T	3	Ritmo natural ligado a ciclos de test; no necesariamente en tiempo real.
I	3	De nuevo, mejora con revisiones externas.
C	3	Supone coste adicional de pruebas dinámicas; razonable si se limita a críticas.

M2.3 – Fases por vulnerabilidad confirmada

Criterio	Puntuación	Justificación resumida
P	3	Más fases no siempre implican mejor resultado; existe punto de rendimiento decreciente.
R	4	Útil para entender madurez del flujo HyVAW.
A	3	Informa ajustes del proceso, pero no indica por sí sola dónde actuar.
G	3	Puede “inflarse” añadiendo fases de poco valor.
M	3	Algo técnica; requiere contexto para no interpretarla como “cuantas más, mejor”.
A	3	Cálculo simple; interpretación más delicada.
T	3	Puede medirse por ciclo de proyecto.
I	4	Menos vinculada a intereses; describe un hecho de proceso.
C	4	Coste de medición bajo si el flujo está instrumentado.

3. Métricas de Gestión y Resiliencia (G3)

M3.1 – TTR vulnerabilidades críticas

Criterio	Puntuación	Justificación resumida
P	5	TTR corto predice menor ventana de exposición; métrica clásica de riesgo operativo. [web:19][web:23]
R	5	Altamente relevante para NIS2 y guías ENISA.[web:18][web:36]
A	5	Directamente accionable: se pueden fijar objetivos, SLAs, recursos.
G	4	Difícil de manipular si se audita cierre real.
M	5	Intuitiva para todos los niveles (“cuánto tardamos en cerrar un agujero grave”).
A	4	Precisión buena con herramientas de ticketing.
T	4	Puede monitorearse mensual o trimestralmente.
I	3	Depende de datos internos; auditorías pueden reforzarla.
C	4	Aprovecha datos ya recogidos para operación.

M3.2 – Cumplimiento de plazos de remediación

Criterio	Puntuación	Justificación resumida
P	4	Alto cumplimiento predice menor acumulación de riesgo residual.
R	5	Directamente conectada a objetivos de política y regulación.
A	5	Facilita medidas disciplinarias, refuerzo de recursos, política de excepciones.
G	3	Puede verse afectada por cierres “administrativos” sin remediación real.
M	4	Significativa, especialmente para cuadros de mando.
A	4	Mismo sustrato de datos que TTR.
T	4	Fácil actualización periódica.
I	3	Mejora con revisiones cruzadas (riesgos, auditoría interna).
C	4	Coste bajo si se integra en sistemas existentes.

M3.3 – Incidentes por vulnerabilidad conocida

Criterio	Puntuación	Justificación resumida
P	5	Alto valor predictivo: si muchas brechas vienen de vulnerabilidades conocidas, hay un problema sistémico.
R	5	Relevancia máxima para NIS2 (fallos de implementación de medidas).[web:18][web:32][web:36]
A	5	Impulsa cambios de gobernanza, priorización, accountability.
G	4	Basada en análisis post-incidente; genuina si el análisis es serio.
M	5	Muy significativa para dirección y regulador: el “pecado original”.
A	3	Precisión depende de calidad de forense y registro de vulnerabilidades.[web:32][web:34]
T	3	Métrica de ritmo lento (incidentes significativos).
I	4	Apoya bien la intervención externa (autoridad nacional).
C	3	Análisis post-incidente tiene coste, pero suele ser obligado.

4. Métricas de Valor y Sostenibilidad (G4)

M4.1 – Coste anual HyVAW por sistema esencial

Criterio	Puntuación	Justificación resumida
P	2	Por sí sola, poco predictiva de seguridad; indica esfuerzo, no resultado.
R	3	Relevante para gestión financiera y benchmarking.
A	3	Útil para ajustar presupuestos relativos por sistema.
G	3	Puede maquillarse “reubicando” costes.
M	3	Significado claro para finanzas; menos para seguridad sin contexto de resultados.
A	3	Precisión razonable si hay buena contabilidad de costes.
T	3	Datos anuales son suficientes.
I	3	Susceptible a decisiones contables internas.
C	4	Datos financieros ya existen; coste bajo de extracción.

M4.2 – Reducción de incidentes significativos

Criterio	Puntuación	Justificación resumida
P	4	Tendencia a la baja sugiere mejora en conjunto de medidas, HyVAW incluido.[web:19] [web:32]
R	5	Central para justificar cualquier inversión en seguridad.
A	4	Permite argumentar continuidad o ajuste de estrategias.
G	3	Difícil atribución exclusiva a HyVAW; riesgo de sobre-atribución.
M	4	Muy significativa a nivel ejecutivo y político.
A	3	Precisión limitada por variabilidad anual y detección.
T	3	Ritmo anual; cambios rápidos no se reflejan de inmediato.
I	4	Datos suelen ser centralizados (INCIBE, CSIRTs).[web:32] [web:34]
C	3	Requiere consolidación y clasificación de incidentes.

M4.3 – ROI HyVAW aproximado

Criterio	Puntuación	Justificación resumida
P	3	Aporta una idea de balance coste/beneficio, pero con alta incertidumbre.
R	4	Importante para alta dirección y planificación presupuestaria. [web:19][web:48]
A	4	Puede influir en decisiones de inversión o desinversión.
G	2	Basado en supuestos de impacto evitado; riesgo de “optimismo creativo”.
M	3	Comprensible, pero requiere explicar supuestos.
A	2	Exactitud limitada por naturaleza contrafactual (“qué habría pasado si...”).
T	3	Actualizable anualmente; valores muy volátiles.
I	3	Cierta dependencia de quién hace los supuestos.
C	2	Coste de cálculo y debate de supuestos no es trivial.

5. Uso de la matriz PRAGMATIC

- Las métricas con puntuaciones globales altas (M1.1, M3.1, M3.3) deberían ser núcleo del cuadro de mando nacional.
- Métricas con debilidades claras (M4.3) deben usarse con cautela y siempre acompañadas de contexto cualitativo.
- El catálogo puede depurarse periódicamente, re-evaluando puntuaciones a medida que mejoran procesos de medición.[web:48]